

Protokoly vyšší úrovně – SSL/TLS

Prof. Ing. Cyril Klimeš, CSc.

SSL/TLS

- SSL (Secure Sockets Layer) a TLS (Transport Layer Security) jsou protokoly, které zajišťují bezpečnou komunikaci přes počítačovou síť, jako je internet.
- SSL/TLS certifikát je digitální certifikát, který ověřuje identitu webové stránky a šifruje data přenášená mezi serverem a klientem (např. webovým prohlížečem).
- To umožňuje bezpečný přenos citlivých informací, jako jsou údaje o kreditní kartě, přes internet.
- Protokol SSL/TLS poskytuje
 - Autentizaci stran –strany jsou autentizovány pomocí certifikátů a protokolu výzva-odpověď
 - Integritu –autentizační kódy (messageauthenticationcode–MAC) zajišťují integritu a autenticitu dat
 - Důvěrnost –po úvodní inicializaci („handshake“), je ustaven symetrický šifrovací klíč, kterým je šifrována všechna následující komunikace (včetně přenosu hesel apod.)

Jak SSL/TLS certifikát pracuje

- 1.Ověření identity:** Když navštívíte webovou stránku, váš prohlížeč požádá server o identifikaci. Server pošle zpět svůj SSL/TLS certifikát, který obsahuje veřejný klíč a informace o identitě serveru.
- 2.Šifrování:** Prohlížeč ověří platnost certifikátu pomocí certifikační autority (CA). Pokud je certifikát platný, prohlížeč a server vytvoří šifrovaný komunikační kanál pomocí veřejného a soukromého klíče.
- 3.Bezpečný přenos dat:** Data přenášená mezi prohlížečem a serverem jsou šifrována, což znamená, že jsou chráněna před odposlechem a útoky typu man-in-the-middle.

Pozice SSL/TLS

- Mezi aplikační vrstvou a protokolem TCP
- SSL/TLS nevidí do aplikačních dat
- SSL/TLS neprovádí elektronické podepisování přenášených dat

Aplikační vrstva

SSL/TLS

TCP/UDP

IP

Linková vrstva

Fyzická vrstva

Klíče v SSL/TLS

- Klient generuje PreMasterSecret, šifruje veřejným klíčem serveru a posílá serveru
- Obě strany vytvoří blok klíčů z PreMasterSecret(posílá se šifrovaně) a náhodných čísel ClientHello a ServerHello(posílají se nešifrovaně)
- Blok klíčů tvoří klíče pro
 - MAC klient → server
 - MAC server → klient
 - Šifrování klient → server
 - Šifrování server → klient
 - Inicializační vektory

Jak pracuje SSL/TLS

SSL /TLS kombinuje asymetrické a symetrické šifrování pro vytvoření zabezpečeného spojení. Proces se odvíjí následovně:

- 1. SSL /TLS podání ruky:** Když se prohlížeč připojí k zabezpečenému webu (HTTPS), server prezentuje své SSL/TLS osvědčení.
- 2. Ověřování:** Prohlížeč ověřuje platnost certifikátu prostřednictvím důvěryhodného Certifikační úřad (CA). Zkontroluje datum vypršení platnosti certifikátu, podpis a zda byl odvolán.
- 3. Vytvoření klíče relace:** Pokud je certifikát platný, prohlížeč vygeneruje symetrický klíč relace. Tento klíč zašifruje pomocí veřejného klíče serveru a odešle jej zpět na server.
- 4. Šifrování:** Server dešifruje klíč relace pomocí svého soukromého klíče. Server i prohlížeč nyní sdílejí symetrický klíč používaný po dobu trvání relace.
- 5. Zabezpečené připojení:** Je navázáno bezpečné spojení se všemi přenášenými daty šifrovanými pomocí symetrického klíče relace.

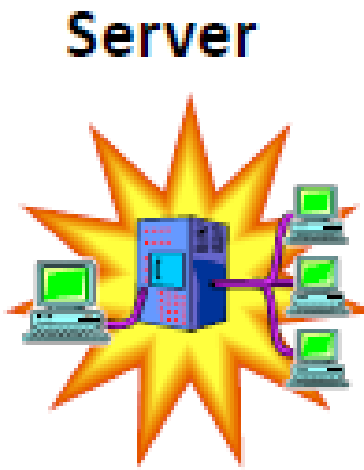
Celý tento proces probíhá v milisekundách, což zajišťuje bezproblémové a bezpečné uživatelské prostředí bez znatelných prodlev.

SSL/TLS



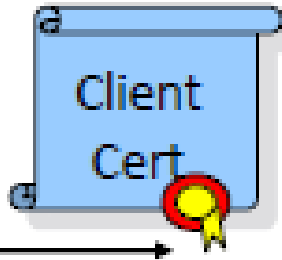
Client

Client Hello

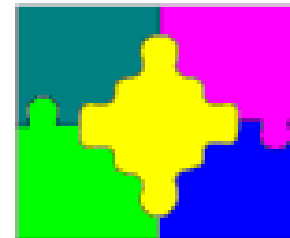


Server

Server Hello, ( , Client Cert Request, ...)

Client Key Exchange, Cipher Spec, ( , ...)

Application



Data

SECURE

Vizuální indikátory SSL/TLS



- **HTTPS v URL:** Přítomnost „https://“ na začátku webové adresy označuje zabezpečené připojení.
- **Ikona visacího zámku:** Visací zámek zobrazený v adresním řádku prohlížeče znamená, že stránka má platné SSL/TLS osvědčení.
- **Název organizace:** Certifikáty EV mohou vedle adresy URL zobrazovat název organizace, ačkoli tato funkce je v některých prohlížečích postupně vyřazována.

Typy SSL/TLS Certifikátů

1. Certifikáty ověřené doménou (DV) - poskytují základní ověření potvrzením vlastnictví domény prostřednictvím ověření e-mailu nebo DNS záznamů. Vydávají se rychle, často během minut až hodin, a jsou obecně nejlevnější variantou. Tyto certifikáty jsou ideální pro osobní blogy, informační weby a malé podniky, které potřebují šifrování bez rozsáhlého ověřování.

- **Použití v konkrétním odvětví:**

- Blogy a osobní stránky: Nabízí rychlé a dostupné zabezpečení pro osobní projekty.
- Interní systémy: Chraňte interní komunikaci v rámci organizace bez potřeby veřejných indikátorů důvěry.

2. Certifikáty ověřené organizací (OV) - nabízejí střední úroveň ověření potvrzením vlastnictví domény a základních informací o organizaci. Vydání obvykle trvá jeden až tři dny a je cenově dostupné. Jsou vhodné pro veřejně přístupné webové stránky, které shromažďují uživatelská data, kde návštěvníci potřebují ujištění o legitimitě organizace.

- **Použití v konkrétním odvětví:**

- Vzdělávací instituce: Zabezpečené portály pro studenty a zaměstnance, které chrání osobní a akademické informace.
- Neziskové organizace: Budujte důvěru dárců a dobrovolníků ověřením identity organizace.

3. Certifikáty rozšířené platnosti (EV) - poskytují rozsáhlé ověření prostřednictvím přísných kontrol právní, fyzické a provozní existence organizace. Jejich vydání trvá jeden až pět dní a jsou nejdražší možností. Certifikáty EV jsou ideální pro weby elektronického obchodu, finanční instituce a významné značky, kde je vyžadována nejvyšší úroveň důvěry.

- **Použití v konkrétním odvětví:**

- Finanční služby: Banky, pojišťovny a investiční společnosti potřebují maximální důvěru, aby zajistily klientům svá bezpečnostní opatření.
- Poskytovatelé zdravotní péče: Chraňte citlivá data pacientů a dodržujte předpisy, jako je HIPAA, předvedením přísných bezpečnostních postupů.

vlastnost	DV	OV	EV
Úroveň ověření	Vlastnictví domény	Doména a organizace	Rozsáhlé ověřování organizace
Vizuální indikátory	Visací zámek	Visací zámek	Visací zámek (někdy název společnosti)
Ideální pro	Blogy, osobní stránky	Obchodní stránky	E-commerce, finanční instituce
Příklady odvětví	Osobní blogy	Školy, nevládní organizace	Banky, online prodejci